



CVE-2025-25257: UNAUTHENTICATED SQL INJECTION IN FORTIWEB GUI

Vairav CVE Report

Date: July 10, 2025

Vairav Cyber Threat Intelligence Team

Vairav Technology Security Pvt. Ltd.

Thirbam Sadak 148

Baluwatar, Kathmandu

Phone: +977 4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

EXECUTIVE SUMMARY

A critical unauthenticated SQL injection vulnerability (CVE-2025-25257) has been identified in the FortiWeb web application firewall. The flaw, stemming from improper input validation in the GUI component, enables remote attackers to execute malicious SQL commands via crafted HTTP/HTTPS requests. The vulnerability affects multiple FortiWeb versions from 7.0 to 7.6. Fortinet has released security patches and recommends immediate upgrades. As a precaution, disabling the HTTP/HTTPS administrative interface is advised until patching is completed.

VULNERABILITY DETAILS

CVE-2025-25257: Unauthenticated SQL Injection in FortiWeb GUI

Description: FortiWeb's GUI component is vulnerable to SQL injections due to improper neutralization of special elements in SQL commands (CWE-89). Attackers can exploit the flaw by sending specially crafted HTTP or HTTPS requests, allowing the execution of unauthorized SQL code or commands.

Impact: May lead to full system compromise, data exfiltration, or unauthorized command execution.

CVSS Score: 9.6 (Critical)

EXPLOITATION

Exploitable remotely and unauthenticated via crafted HTTP/HTTPS requests targeting the GUI.

AFFECTED PRODUCTS/VERSIONS

- FortiWeb 7.6.0 through 7.6.3
- FortiWeb 7.4.0 through 7.4.7
- FortiWeb 7.2.0 through 7.2.10
- FortiWeb 7.0.0 through 7.0.10

Patched Versions:

- FortiWeb 7.6.4 and above
- FortiWeb 7.4.8 and above

- FortiWeb 7.2.11 and above
- FortiWeb 7.0.11 and above

RECOMMENDATION

- Disable the HTTP/HTTPS administrative interface to reduce attack surface.
- Implement additional controls such as network segmentation, access restrictions, and monitoring.

REFERENCES

<https://cybersecuritynews.com/fortiweb-sql-injection-vulnerability/>

<https://fortiguard.fortinet.com/psirt/FG-IR-25-151>

CONTACT US

Vairav Technology Security Pvt. Ltd.

Cyber Defender from the land of Gurkha

Thirbam Sadak 148, Baluwatar

Kathmandu, Nepal

Phone: +977-01-4541540

Mobile: +977-9820105900

Email: sales@vairavtech.com

Website: <https://vairavtech.com>